AI Governance Foundations

Chapter 01 · Episode 1 — Dr. Michael Solomon



This Episode

1. How to structure AI governance
2. What a complete program contains
3. Three models: central · federated · hybrid
4. Six program components

The Heaviest Domain

Domain 1 — most-tested on the exam

Structures · roles · responsible AI

Risk · shadow AI · frameworks

Policies · third-party sovereignty



Governance Structures

Who decides how AI is used?

Directed · controlled · accountable

Exam: structures · roles · policies



AI Center of Excellence

Centralized cross-functional team

AI/ML · security · legal · ethics · ops

The primary delivery structure



Three CoE Functions

SET — Standards: use · testing · monitoring

ENABLE — Guidance + reusable components

EVALUATE — Risk review before deployment



Governance Committees

Senior leadership decision body

Legal · infosec · privacy · business

They decide — the CoE implements



Duties & Escalation

Approve use cases · set tolerance

Review incidents · reg alignment

Escalation thresholds documented

Risk-based: sensitivity · automation · scope



AI Governance Policies



ALLOW

Acceptable use — apps · purposes · data



DATA

Classification · privacy standards



PROHIBIT

Explicitly banned AI uses



VENDORS

Third-party AI requirements

ENFORCEMENT

Technical controls block unapproved AI

Procurement: AI vendor evaluation

Audits verify ongoing compliance



Six Program Components

The pillars of a complete AI governance program

Any one missing or immature = a structural gap

Every later episode builds on one or more

Recap

Three models shape accountability

Board → executive → operational

Six components = the pillars

Next: steering committees & charters



Steering Committees & Charters

Chapter 01 · Episode 2 — Dr. Michael Solomon

What a Steering Committee Is

Cross-functional membership

Formal decision authority

Empowered to act — not advisory



THE CHAIR

The most critical structural decision

Sets agenda, drives decisions

Owns outcomes between meetings



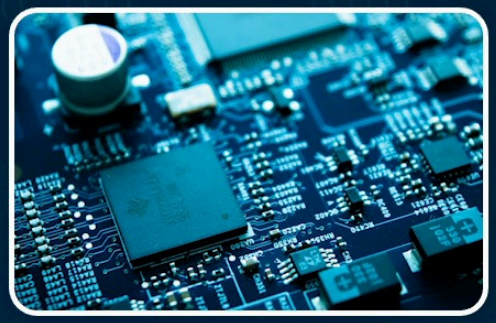
Six Membership Domains



SECURITY
CISO



LEGAL
General Counsel



TECH
CTO / AI Owner



RISK/BIZ
CRO · Business · Audit

Voting, Non-Voting & Quorum

Voting members hold authority

Non-voting SMEs attend as needed

Quorum prevents rogue decisions



The Charter

The committee's constitution — not an agenda



Six Charter Components

Purpose / scope

Authority & limits (most critical)

Membership & operating procedures

Escalation paths · accountability



The Governance Workflow

1 · Request raised

2 · Operational review

3 · Steering committee

4 · Board escalation



Maturation: Three Phases

Establish — charter, chair, members

Operate — cadence, minutes, KPIs

Mature — annual review, rotation



Stakeholder Identification & Accountability

Chapter 01 · Episode 3 — Dr. Michael Solomon



This Episode

1. Map the full stakeholder landscape
2. Apply the RACI model
3. Spot the common accountability gaps
4. Diagnose failures from a scenario

Ownership Fails First

67% of AI project failures cite unclear ownership

Root cause is people, not technology

Stakeholder mapping prevents the gap



Three Questions

Who has authority?

Who is accountable?

Who must be informed?



Stakeholder Domains 1–3

Executive leadership — sets risk appetite

Security & risk — CISO/CRO own posture

Data & AI teams — build and operate



Stakeholder Domains 4–6

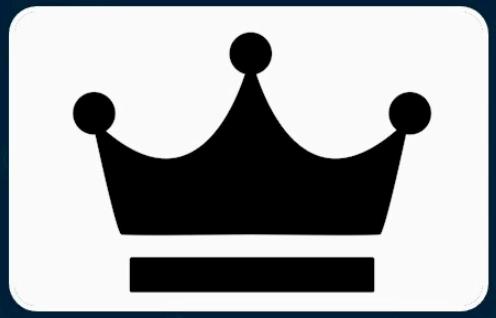
Legal & compliance — GC/DPO, ethics review

Business owners — fund; speed pressure

Audit & governance — independent assurance



The RACI Model



RESPONSIBLE

Executes the work — can be shared



CONSULTED

Provides required input



ACCOUNTABLE

Owns the outcome — exactly one



INFORMED

Notified of results only

The One-A Rule

Exactly one Accountable per activity

Most-tested RACI concept

Two A's = nobody is accountable



Key Program Roles

Chief AI Officer — accountable exec

AI Security Officer (CISO) — controls, IR

AI & Compliance Lead — register, audit

Business AI Owner — sponsor, not governance



Reporting Lines

Governance roles → enterprise risk

Business owners → the business

Separation shields governance decisions



Five-Step Identification

1 Scope — systems, use cases, functions

2 Map the six functional domains

3 Apply RACI to key activities

4 Validate — confirm with each party

5 Document & maintain — review annually

Accountable vs Responsible

ACCOUNTABLE

Owns the outcome

Exactly one person

Cannot be shared

RESPONSIBLE

Executes the work

Can be many people

Sharing is fine

Four Accountability Gaps



DIFFUSE

Multiple A's — nobody truly owns it



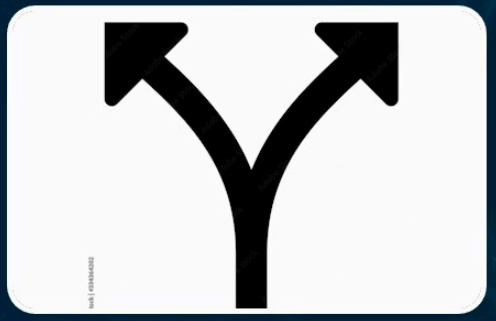
AUTHORITY, NO A

Decides in charter, no RACI A



MISSING

Key function (legal/audit) left off



A, NO AUTHORITY

Named A can't direct the work

Recap

Six domains · RACI · one-A rule

Five-step process · four gap patterns

Exam: diagnose the gap from a scenario



Risk Appetite & Risk Tolerance

Chapter 01 · Episode 4 — Dr. Michael Solomon

Appetite vs Tolerance

Appetite — board-level strategic statement

Tolerance — measurable operational band

Both documented in the program plan

Verbal commitments aren't evidence



Two Distinct Concepts

APPETITE

Qualitative

Board-level · strategic

Set by steering committee

TOLERANCE

Quantitative

Operational · measurable

Set by AI security lead

Worked Example

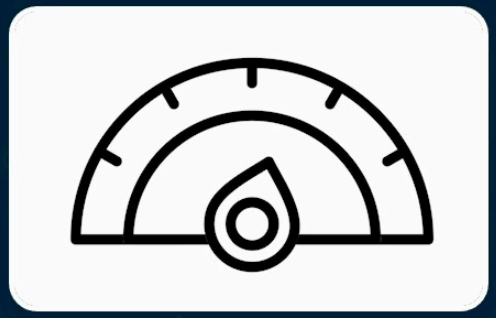
Appetite: residual risk medium or below

Tolerance: fairness variance ≤ 10%

Strategic vs measurable, side by side



Four Appetite Dimensions



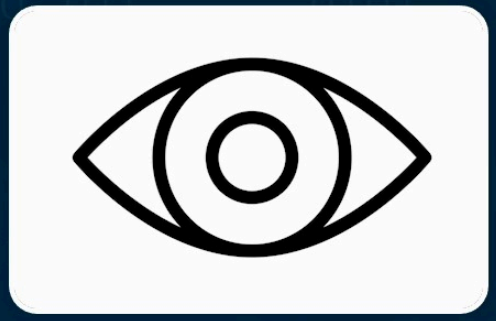
OPERATIONAL

Errors & performance loss



REGULATORY

Noncompliance — capped by law



REPUTATIONAL

Discriminatory or harmful outputs



STRATEGIC

Capability limits vs objectives

Thresholds

Turn appetite into per-system limits

Fairness bands · accuracy · SLAs · drift

Tier-1 tighter than tier-3

Feed KRI monitoring dashboards



Every Decision Checks Appetite

Within — proceed & document

At boundary — named approval

Above — escalate, treat or pause



Risk Register Linkage

Every entry rated against appetite

Above appetite needs board sign-off

Appetite change = reassess all entries



Treatment & Review

Above-appetite risks funded first

Annual review = appetite adequacy check



Regulatory Links

EU AI Act high-risk — no noncompliance

GDPR Article 22 — automated decisions

Third-party appetite feeds vendor tiering



Four Failure Patterns



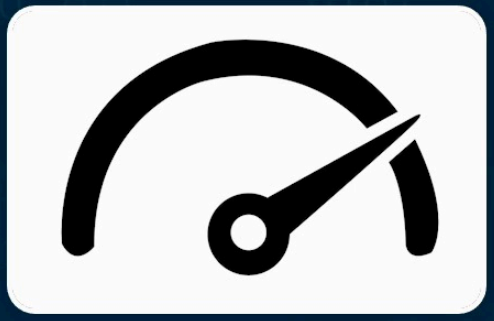
NO SIGN-OFF

Security lead sets appetite alone



PRE-BASELINE

Thresholds set before production data



NO THRESHOLDS

Appetite exists, no operating limits



STALE APPETITE

Not reviewed after strategy change

Recap

Appetite vs tolerance · four dimensions

Thresholds · decisions · register linkage

Regulatory appetite is capped by law



Wiring it together

Document both in program plan §1

Reference in every governance artifact

Review annually & on material change



Framework Selection & Regulatory Alignment

Chapter 01 · Episode 5 — Dr. Michael Solomon



Three Framework Pillars

1. EU AI Act — mandatory regulation
2. NIST AI RMF — voluntary governance structure
3. ISO 42001 + OECD — international standards

EU AI Act

World's first comprehensive AI regulation

In force August 2024

Risk-tiered: obligations scale with potential harm



Extraterritorial Scope

Applies to AI placed on or used in the EU market

And to AI outputs used in the EU

May reach systems deployed anywhere that affect EU users



Four EU AI Act Risk Tiers

1 Unacceptable

Prohibited — banned entirely in the EU

2 High Risk

Strict pre-market assessment + monitoring

3 Limited Risk

Transparency / disclosure obligations

4 Minimal Risk

No specific obligations; voluntary codes



Tier 1 · Prohibited AI

Social scoring by public authorities

Real-time remote biometric ID in public (narrow exceptions)

Subliminal manipulation; exploiting group vulnerabilities



Tier 2 · High-Risk Categories

Critical infrastructure

Education & employment decisions

Access to essential services

Law enforcement & administration of justice



Tier 3 · Limited Risk — Disclosure

Chatbots must identify themselves as AI

Deepfake content must be labeled synthetic

Emotion-recognition systems must be disclosed



Tier 4 · Minimal Risk

Spam filters, games, low-stakes recommendations

No specific obligations — voluntary codes of conduct

Exam: know an example + obligation for each tier



Seven High-Risk Requirements

Risk management across the lifecycle
Data governance
Technical documentation
Record-keeping (automatic logs)
Transparency to users
Human oversight
Accuracy, robustness & cybersecurity



Conformity Assessment

Required before a high-risk system reaches market

Self-assessment or third-party, by category

Scenario Qs may describe a missing requirement



General-Purpose AI (GPAI)

Publish a summary of training data used

Comply with EU copyright law

Provide technical docs to downstream deployers



GPAI Systemic Risk

Triggered by training compute above a threshold

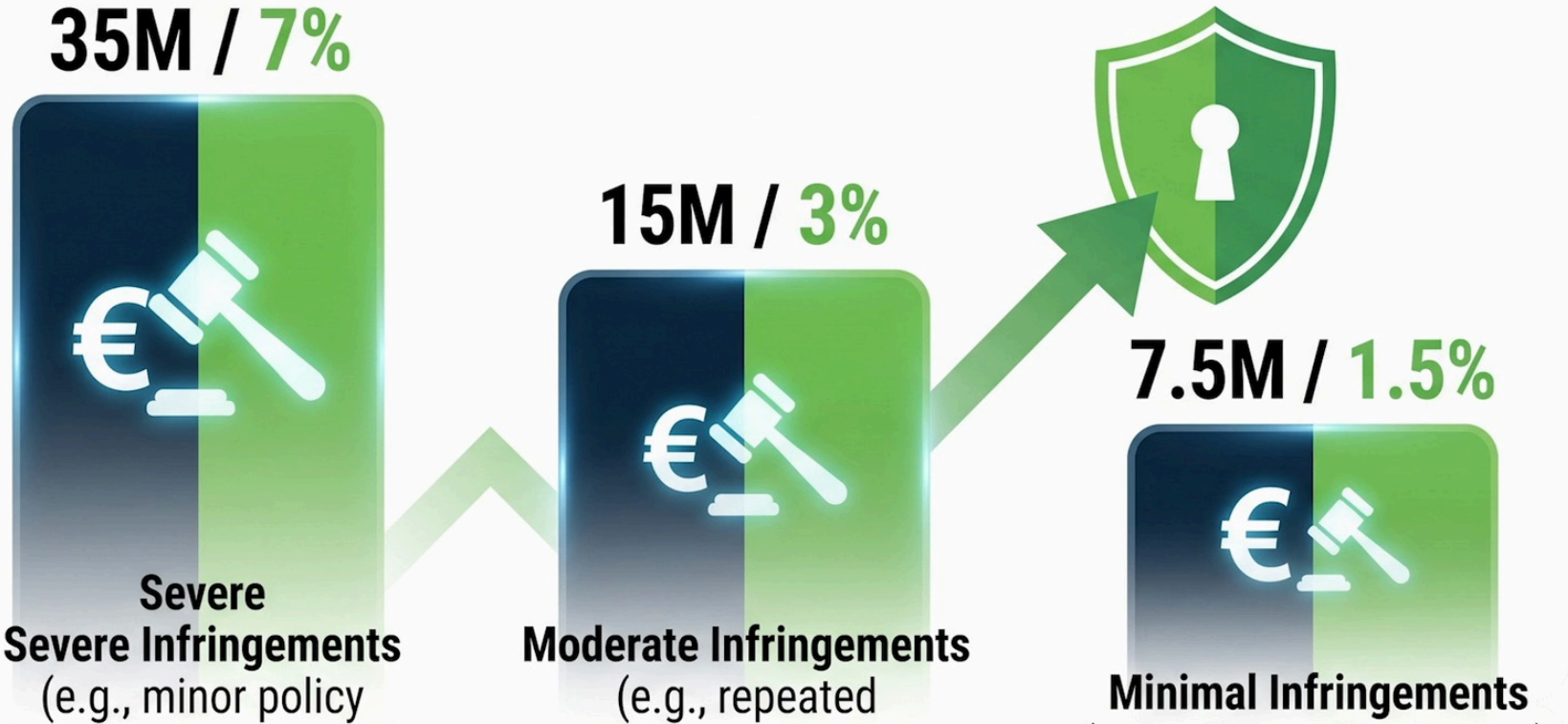
Adversarial testing + incident reporting to the EU AI Office

Cybersecurity protection measures

Enforced by national authorities + the EU AI Office



PENALTY TIER ESCALATION FRAMEWORK



ISACA

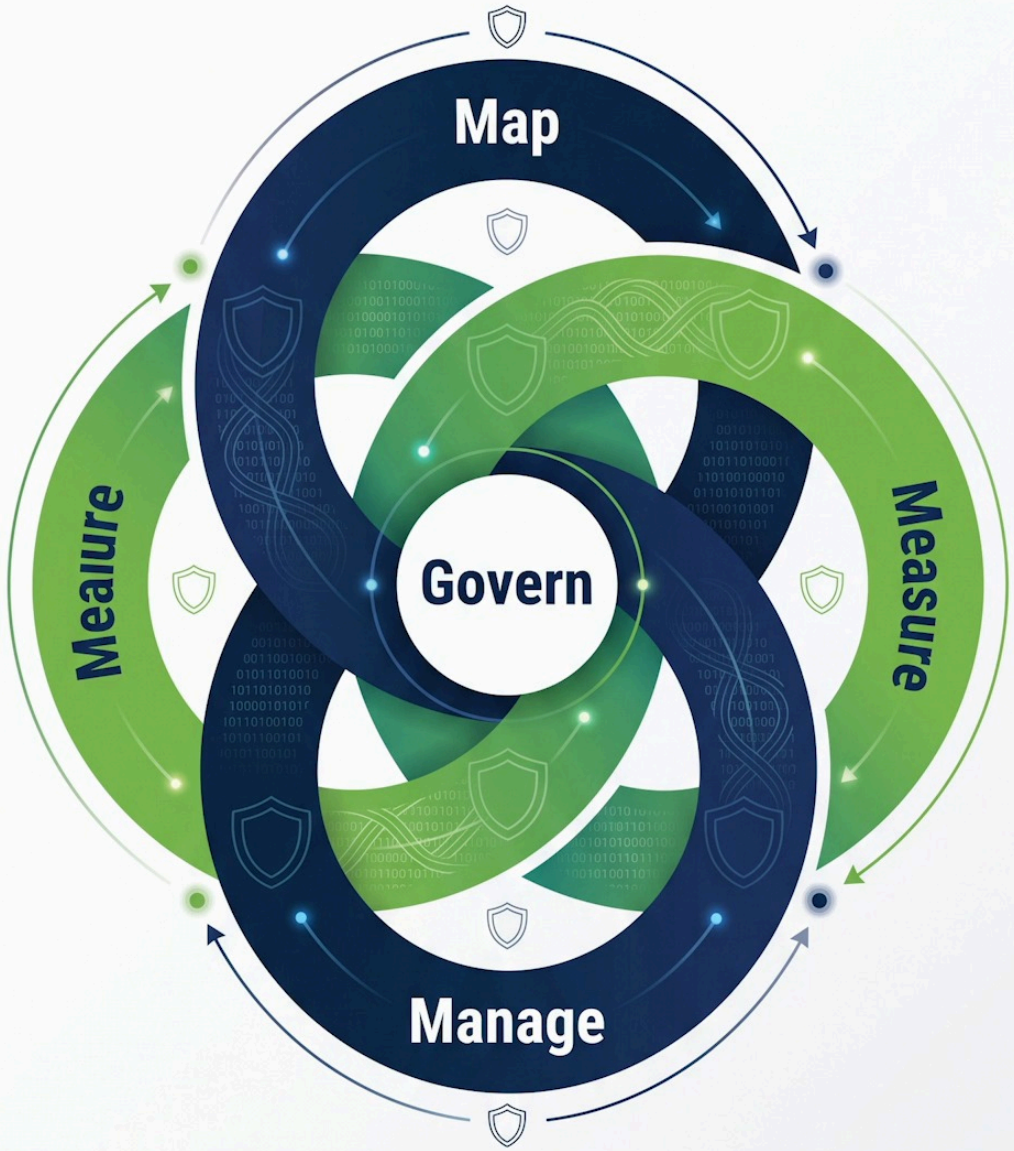
NIST AI RMF

US government voluntary framework, released Jan 2023

Directly tested; a global governance-maturity benchmark

Structured risk approach across the AI lifecycle




Map
Measure
Manage
Measure
Govern

Govern — Foundational

Policies, roles, and organizational risk tolerance

Senior-leadership & board engagement; risk-aware culture

Cross-cutting — informs every other function

Absent if there's no risk tolerance, roles, or policy



Map — Context & Risks

Categorize systems by use, stakeholders, impacts

Applicable laws + potential harms to people & society

Data inputs and their provenance

Missing if there's no grasp of who's affected



Measure — Analyze & Quantify

Bias/fairness assessments + adversarial red-teaming

Performance vs benchmarks; control effectiveness

Production monitoring of AI behavior

Missing if severity/likelihood aren't assessed



Manage — Respond & Refine

Implement controls; allocate resources by severity

Incident response + residual-risk acceptance

Feedback loops return intelligence to Map & Measure

A never-updated assessment = a broken Manage function



ISO 42001 & OECD

ISO/IEC 42001 — international AI management-system standard

OECD AI Principles — first intergovernmental standard (2019)

ISO 42001 mirrors ISO 9001 / 27001 structure



ISO/IEC 42001 Key Requirements

Organizational context + leadership commitment

Planning: AI objectives + risk treatment

Support, operation, performance evaluation

Improvement — the certifiable AMS framework



Five OECD AI Principles

Inclusive growth & well-being
Human-centered values & fairness
Transparency & explainability
Robustness, security & safety
Accountability



ISO 42001 vs NIST AI RMF

ISO 42001 — certifiable via third-party audit, global

NIST AI RMF — voluntary US guidance, no certification

Complementary: run NIST, certify to ISO 42001



Layered Governance Architecture

EU AI Act — minimum legal requirements

NIST AI RMF — operational risk-management process

ISO 42001 — certifiable management-system structure

OECD — ethical-principles foundation



COMPLEMENTARY, NOT REDUNDANT

Exam Tip

Each framework contributes a distinct dimension

Scenario Qs: which framework element is missing?



AI Business Use Case Governance

Chapter 01 · Episode 6 — Dr. Michael Solomon

Use Case Intake

Standardized form: purpose · data · owner

No deployment without a completed intake

Unregistered deployment = program gap



Risk Assessment at Intake

Classify vs the four appetite dimensions

EU AI Act classification

Personal · special · automated data



Three Governance Tracks

STANDARD — tier 3

ENHANCED — tier 2

FULL COMMITTEE — tier 1 / high risk



Track Requirements

Standard — program-team review, inventory

Enhanced — security lead, DPIA, monitoring

Full — steering approval + architecture gate

Routing driven by the risk score



Business Owner Accountability

Sponsor owns the business case

Not the governance program

Confirms purpose · users · outputs · success

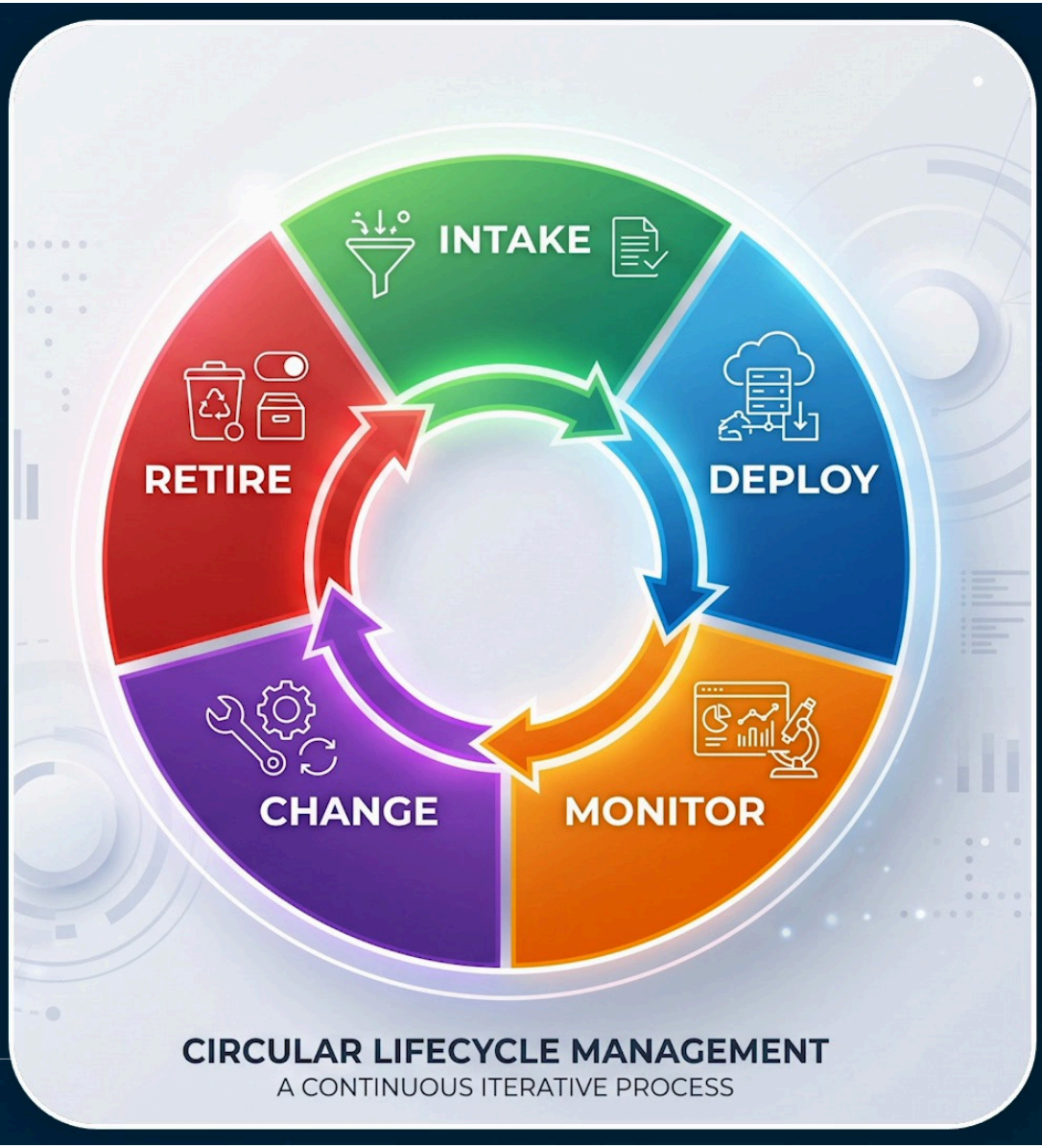


Post-Approval Governance

Deploy → asset inventory + monitoring

Material change → change management

Decommission → retirement procedure



AAISM Additions

Intake captures EU AI Act class + purpose

Annex III high-risk → FRIA before deploy

Intake retained as governance evidence



Four Failure Patterns

NO INTAKE

Deployed with no intake record

WRONG TRACK

HR AI routed through standard

OWNER BYPASS

Sponsor approves own use case

NO RETIREMENT

Switched off, no procedure



The Fixes

Intake mandatory for all deployments

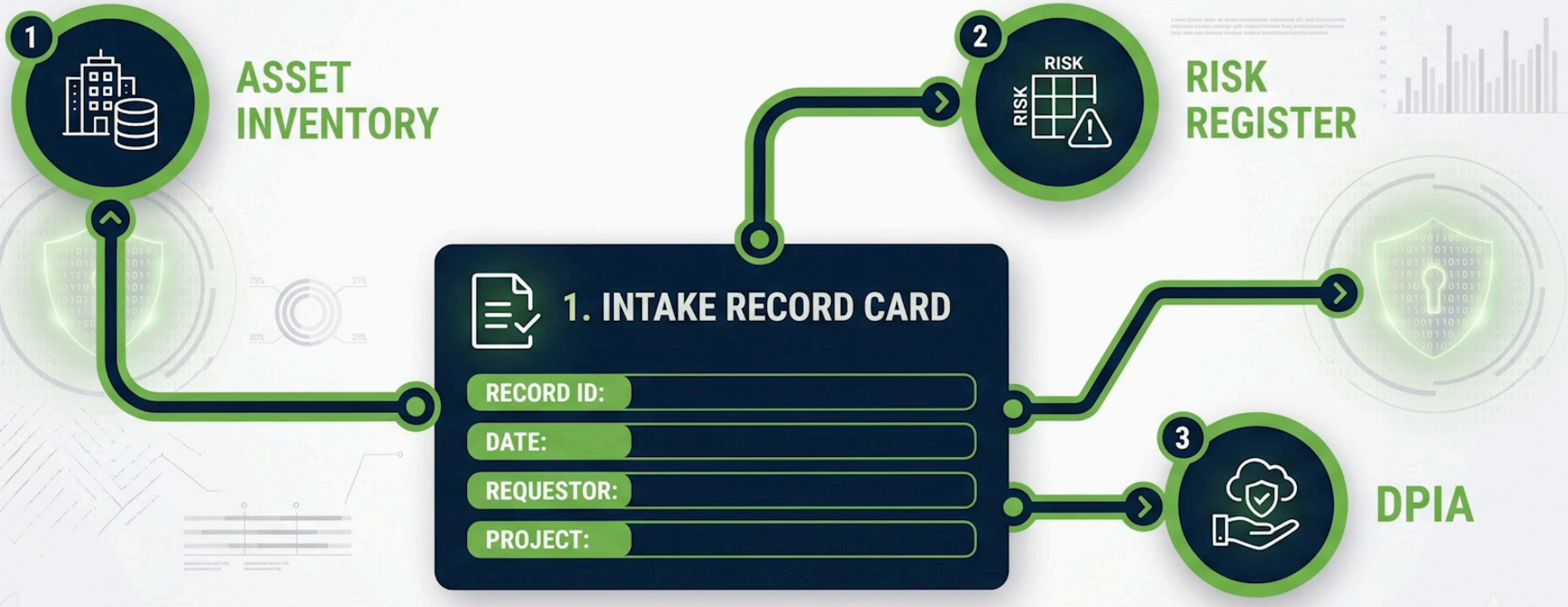
Track assigned by the AI program team

Governance SLA so speed can't bypass

Retirement procedure enforced



AUDITABLE GOVERNANCE TRAIL



AI Strategy: Consumer vs Enterprise

Chapter 01 · Episode 7 — Dr. Michael Solomon

Consumer vs Enterprise

CONSUMER AI

Wider user population

Higher regulatory scrutiny

Transparency to end users

ENTERPRISE AI

Narrower population

Internal accountability

Operational efficiency

Enterprise & the HR Trap

Obligations mainly to employees

Exception: HR AI = high-risk (Annex III)

Same FRIA as consumer high-risk

HR AI is not exempt — exam trap



Build vs Buy

Build → provider obligations

Buy / API → deployer + vendor DD

Fine-tune a vendor model → deemed provider

Legal review before proceeding



Foundation Model Strategy

GPAI APIs create downstream duties

Document provider tech docs + copyright

You own your system's risk class

Contract for model-change notification



Portfolio Governance

Govern the AI strategy as a portfolio

Concentration risk: one shared model

Asset inventory = the portfolio tool



AAISM Additions

Strategy doc: governance per model

Model shift → reclassification

Annual review = governance adequacy

Strategy is a governance input



Recap

Consumer vs enterprise · buy vs build

Foundation model · portfolio

HR AI = high risk; build = provider

Fine-tune = deemed provider



Four Failure Patterns

Exam Tip

NO IMPLICATIONS

Strategy omits EU AI Act roles

NO TRANSPARENCY

Consumer AI, no Article 22 notice

FINE-TUNE ≠ MOD

Own-name deploy, no legal review

GPAI UNMAPPED

Shared model, no concentration entry



Strategy Drives Governance

Fine-tune under your name = deemed provider

GPAI dependency = concentration risk

Document rationale per deployment model

Program plan reflects current strategy

